PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Administration sécurisée des SI

03-500 ANSSI - Recommandations relatives à l'administration sécurisée des systèmes d'information — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le SI d'administration doit faire l'objet d'une analyse de risque propre et de zones d'administration définies selon les zones de confiance du SI administré.
2. Les architectures de poste d'administration sont classées par ordre de sécurité décroissant : poste dédié, poste multi-niveaux ou accès distant au SI bureautique.
3. L'administration par des tiers doit passer par un prestataire PAMS qualifié et utiliser un rebond éphémère pour garantir la traçabilité.

Administrateurs et analyse de risque

Notion	À retenir
Les administrateurs	Doivent être **informés** de leurs droits/devoirs et **formés** à l'état de l'art ; l'entité doit avoir une **documentation à jour**.
Analyse et zones	Mener une **analyse de risque** sur le SI d'administration et son écosystème ; définir les **zones d'administration** selon les zones de confiance du SI administré.

Le poste d'administration

Notion	À retenir
Gestion et architecture	3 architectures par ordre de sécurité décroissant : **poste dédié**, **poste multi-niveaux** (cloisonnement technique) ou **accès distant au SI bureautique**.
Mesures de sécurisation	Bloquer **tout accès à Internet**, durcir l'**OS**, restreindre les **droits d'administration** locaux, limiter les **logiciels** et chiffrer les **périphériques de stockage**.

Le réseau d'administration

Notion	À retenir
Protection des ressources	Réseau **physique dédié** ou **VPN IPsec dédié** ; filtrage **interne**, **périmétrique** et **local** sur les ressources administrées.
Interface et réseau étendu	Interface **physique** ou **virtuelle dédiée** ; filtrage entre ressources ; **blocage** des connexions entre ressources administrées via le réseau d'administration ; flux sur **réseau tiers** protégés.
Outils d'administration	Sur **serveurs dédiés** par zone d'administration, filtrés depuis les postes ; **protocoles sécurisés**, au besoin dans un **VPN IPsec** ; **rupture protocolaire** à étudier, sauf si elle contredit un besoin de confidentialité.

Comptes, authentification et droits

Notion	À retenir
Comptes d'administration	Utiliser des comptes **dédiés** et **individuels** (pas génériques). Usage réservé à l'administration. Annuaire protégé, événements **journalisés** et gestion du **cycle de vie** prévue.
Authentification et droits	Mots de passe par défaut **modifiés**, stockés en **coffre-fort dédié**. Privilégier l'**authentification double facteur** et les **certificats électroniques de confiance**. Droits par **groupes** selon le **moindre privilège**.
MCS, sauvegarde, supervision	MCS scrupuleux : **serveurs relais** de mises à jour, correctifs **validés** avant généralisation ; politique de **sauvegarde** ; **zone dédiée à la journalisation**, collecte **centralisée** des journaux.

Nomadisme et systèmes d'échanges

Notion	À retenir
Poste nomade	**Filtre de confidentialité** ; connexion par **tunnel VPN IPsec** non modifiable par l'utilisateur ; **concentrateur VPN IPsec physique dédié** à l'administration à distance.
Systèmes d'échanges sécurisés	Système **interne dédié** au SI d'administration ; vers l'**externe**, seuls des protocoles autorisés, accès au **strict besoin** ; jamais de **compte d'administration** pour s'y authentifier ; aucun stockage permanent ; contenu **analysé**.

Administration par des tiers et assistance

Notion	À retenir
Infogérance et tiers	Prestation **PAMS** qualifiée. Poste sécurisé **état de l'art**, chaîne dédiée (**VPN IPsec** ou `TLS`), comptes dédiés (annuaire propre), activés **à la demande**, authentification renforcée et **rebond éphémère** avec traçabilité.
Assistance à distance	Utiliser un **boîtier matériel d'acquisition vidéo** ou, à défaut, une **solution logicielle collaborative dédiée**.

Les cas particuliers d'architecture

- **Usage d'un bastion**
- **Mutualisation** possible du poste d'administration
- **Choix** entre une ou plusieurs solutions de poste d'administration
- **Administration** des ressources d'administration elles-mêmes
- **Administration** d'un SI déconnecté
- **Administration** de ressources hébergées dans un cloud public

Pièges et confusions

⚠ Croire que le cloisonnement d'environnements virtualisés est totalement fiable pour les équipements de sécurité.
⚠ Envisager l'accès distant au SI bureautique comme une solution de premier choix plutôt qu'en dernier recours.
⚠ Utiliser un compte d'administration pour l'authentification sur un système d'échange externe.
⚠ Privilégier la virtualisation pour les équipements de sécurité au lieu de socles physiques distincts.

Sigles et définitions

SI d'administration	Ensemble des postes, réseaux, outils et comptes utilisés pour administrer les ressources d'un SI.
Zone de confiance	Regroupement de ressources du SI administré partageant un même niveau de sensibilité.
PAMS	Prestataire d'infogérance qualifié par l'ANSSI pour l'administration à distance.
Rebond éphémère	Ressource intermédiaire temporaire, créée puis détruite pour chaque session.
Rupture protocolaire	Action de casser puis reconstruire la communication au niveau d'une couche du modèle OSI.

Auto-test

1. Quelles sont les 3 architectures de poste d'administration par ordre de sécurité décroissant ?
2. Quel type de compte doit-on utiliser pour l'administration ?
3. Que doit-on faire des mots de passe par défaut ?
4. Quelle est la méthode recommandée pour l'authentification ?
5. Comment doit être gérée la gestion des droits ?

Réponses : **1.** Poste dédié, poste multi-niveaux ou accès distant au SI bureautique. · **2.** Des comptes dédiés et individuels. · **3.** Ils doivent être modifiés et stockés en coffre-fort dédié. · **4.** Privilégier l'authentification double facteur et les certificats électroniques de confiance. · **5.** Par groupes selon le moindre privilège.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.